

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Field	Value
Report ID	CLD-IR-0002
Related ticket	CLD-0002
Report title	Payroll Phishing Campaign and Credential Compromise
Analyst	Lokesh Sivaprakash
Date of report (UTC)	2026-08-25
Incident severity	P1
Status	Open
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Four to five sentences a non-technical executive can read in 60 seconds: what happened, how it was found, what the attacker did, what has been done about it, and what the business risk was. No IP addresses, no query syntax, no acronyms without explanation.

Cloudora was targeted by a payroll-themed phishing campaign that led two employees to submit credentials. The investigation used message-trace and sign-in evidence to identify successful account access from an unfamiliar location and device. The attacker accessed Microsoft 365 services through both compromised accounts. The confirmed business risk was unauthorized access to employee cloud accounts and possible exposure or misuse of company information.

2. Incident timeline

Every significant event in order, all times in UTC. Include attacker actions, victim actions, and response actions. Cite the log source for each row.

Time (UTC)	Source	Event	Evidence / notes
2026-08-25T08:04Z–08:50Z	Message Trace	Payroll phishing variants delivered.	Variant A spoofed Cloudora; Variant B used the lookalike domain.
2026-08-25T08:39:03Z	Message Trace	Seth Lane clicked the phishing link.	CredentialsSubmitted = No.
2026-08-25T08:47:12Z	Message Trace	Freya Lynn clicked and submitted credentials.	Variant A; CredentialsSubmitted = Yes.
2026-08-25T09:05:44Z	Message Trace	Ryan Boyd clicked and submitted credentials.	Variant B; CredentialsSubmitted = Yes.
2026-08-25T09:58Z / 10:12Z / 11:47Z	Message Trace	Three additional users clicked.	Hugo Marsh, Chloe Price, and Dina Said; no credential submission.
2026-08-25T10:34:20Z	Sign-In Logs	Freya's account successfully logged in from Amsterdam.	198.18.7.200; Windows 11/Chrome.
2026-08-25T10:36:05Z / 10:41:48Z	Sign-In Logs	Attacker accessed Freya's Outlook and SharePoint.	Same IP, Amsterdam, Windows 11/Chrome.
2026-08-25T13:22:05Z	Sign-In Logs	Ryan's account successfully logged in from Amsterdam.	198.18.7.200; Windows 11/Chrome.
2026-08-25T13:25:33Z / 13:43:49Z	Sign-In Logs	Ryan's Outlook was accessed; normal London activity resumed.	Attacker access followed by normal user activity.

3. Findings

One numbered finding per distinct fact you established. State the finding in one sentence, then the evidence (which query, which rows), then why it matters. Findings are facts, not guesses - if you are inferring, say so.

Finding 1

Finding 1: Two employees submitted credentials through the phishing campaign. Evidence: Message-trace click rows show Freya at 08:47:12Z and Ryan at 09:05:44Z with CredentialsSubmitted = Yes. Why it matters: both accounts required immediate compromise assessment.

Finding 2

Finding 2: Freya's submitted credentials were followed by an anomalous successful cloud login. Evidence: normal Manchester/iOS activity at 08:29:33Z was followed by Microsoft 365 success from 198.18.7.200 in Amsterdam at 10:34:20Z using Windows 11/Chrome, then Outlook and SharePoint access. Why it matters: the sequence supports unauthorized use of harvested credentials.

Finding 3

Finding 3: The same attacker infrastructure successfully accessed both Freya's and Ryan's accounts. Evidence: the attacker-IP pivot returned 198.18.7.200 in Amsterdam for Freya at 10:34:20Z–10:41:48Z and Ryan at 13:22:05Z–13:25:33Z. Why it matters: confirmed scope is two compromised accounts.

Finding 4

Finding 4: Ryan's account showed the same phishing-to-account-takeover pattern. Evidence: Ryan's normal London/iOS sign-in was at 08:12:48Z; credential submission occurred at 09:05:44Z; a successful Amsterdam/Windows 11/Chrome login followed at 13:22:05Z. Why it matters: this sequence is consistent with valid credentials being used by an unauthorized party.

4. Indicators of compromise (IOCs)

Everything another analyst would need to detect or block this attacker: IP addresses, device names, rule names, user agents. One row per indicator, with where you found it.

Type	Value	First seen (UTC)	Context
IPv4	198.18.7.200	2026-08-25T10:34:20Z	External Amsterdam IP used for successful sign-ins to both compromised accounts.
Domain	cloudora-hr-portal.example	2026-08-25T08:47:12Z	Lookalike phishing domain used for credential harvesting.
URL	https://cloudora-hr-portal.example/payroll/login	2026-08-25T08:47:12Z	Credential-harvesting URL clicked by Freya.
URL	https://login.cloudora-hr-portal.example/verify	2026-08-25T09:05:44Z	Credential-harvesting URL clicked by Ryan.
IPv4	198.51.100.20	2026-08-25T08:47:12Z	Freya's ClickIP / known Manchester baseline.
IPv4	203.0.113.10	2026-08-25T09:05:44Z	Ryan's ClickIP / known London baseline.
Campaign	PayrollPhish-A	2026-08-25T08:47:12Z	Campaign associated with Freya's credential submission.
Campaign	PayrollPhish-B	2026-08-25T09:05:44Z	Campaign associated with Ryan's credential submission.

5. MITRE ATT&CK mapping

Map only attacker behaviour actually observed in the evidence.

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Spearphishing Link	Finding 1
Credential Access	T1598.003	Phishing for Information	Finding 1
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Findings 2-4

6. Scope

Accounts confirmed compromised

freya.lynn@cloudora.io - compromised: credential submission 08:47:12Z; attacker access 10:34:20Z from 198.18.7.200 in Amsterdam; Outlook and SharePoint accessed.

ryan.boyd@cloudora.io - compromised: credential submission 09:05:44Z; attacker access 13:22:05Z from the same IP/location; Outlook accessed.

Accounts targeted but not breached

seth.lane@cloudora.io, chloe.price@cloudora.io, hugo.marsh@cloudora.io, dina.said@cloudora.io - clicked the phishing link with CredentialsSubmitted = No; no compromise established from supplied sign-in evidence.

Accounts investigated and cleared (false positives)

Cloudora Monthly newsletter - investigated and cleared as legitimate; supplied evidence showed aligned SPF/DKIM/DMARC authentication for cloudora.io and legitimate Mailchimp delivery.

7. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Time (UTC)	Action	Performed by	Verified how
2026-08-25T14:00:00Z (approx.)	1. Revoked all active sessions and refresh tokens for freya.lynn and ryan.boyd.	Cloudora IT / Security Operations	Live sessions invalidated before reset.
2026-08-25T14:00:00Z (approx.)	2. Reset credentials for both compromised accounts.	Cloudora IT / Security Operations	New passwords required after session revocation.
2026-08-25T14:00:00Z (approx.)	3. Required and re-registered MFA on both accounts.	Cloudora IT / Security Operations	MFA required so a harvested password alone is insufficient.
2026-08-25T14:00:00Z (approx.)	4. Blocked 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200 and cloudora-hr-portal.example at the mail gateway and web proxy.	Cloudora IT / Security Operations	Known phishing and attacker infrastructure blocked.
2026-08-25T14:00:00Z (approx.)	5. Purged delivered phishing messages from mailboxes (soft delete / ZAP).	Cloudora IT / Security Operations	Remaining copies removed from user mailboxes.
2026-08-25T14:00:00Z	6. Re-ran victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity remained	Cloudora Security	Containment verified in the

(approx.)	after containment.	Operations	available sign-in evidence.
-----------	--------------------	------------	-----------------------------

8. Recommendations

What the client should change so this attack fails next time. Be specific and prioritised: quick wins first, then strategic changes. Every recommendation should trace back to a finding.

P1: Apply precautionary password resets and direct check-ins for the four clicked-but-no-credential staff; send awareness communications to the thirty near-miss recipients (Findings 4-5). P1: Enforce MFA on all accounts and disable legacy authentication paths that bypass it (Finding 3). P2: Move cloudora.io DMARC policy to p=reject so spoofing variants like Variant A are rejected rather than merely quarantined (Finding 2). P2: Add mail-gateway detection for newly registered lookalike domains and external mail whose From is cloudora.io but fails DMARC (Findings 1-2). P2: Deploy a detection for a successful sign-in from a new country within a few hours of a phishing-link click; this would have alerted on both compromises the same morning (Finding 3). P2: Block phishing infrastructure permanently and monitor for adjacent lookalike-domain registrations (Findings 1-2).

9. Lessons learned

What worked: message-trace scoping moved the investigation from the reported email to affected users, and the attacker-IP pivot identified the second compromised account. What was slow or missing: the supplied evidence does not include timestamped response actions or post-containment verification, so completed remediation cannot be independently documented. The SOC should improve by correlating phishing clicks with subsequent anomalous successful cloud sign-ins and by recording exact UTC timestamps for containment, eradication, and verification.

Template notes: keep all times UTC; write findings as you work, not at the end; the executive summary is written last but appears first.